Segurança de Dados na Nuvem

Introdução

A nuvem mantém dados e recursos computacionais, desta forma existem diferentes perspectivas sobre como proteger os dados e os recursos, pois possuem dinâmicas diferentes, estão baseados em infraestrutura específica e são suscetíveis a diferentes formas de ataques.

Nesta aula vamos compreender como é a proteção dos dados na nuvem e de que forma o usuário está envolvido neste processo, pois mesmo que o provedor mantenha recursos robustos para a proteção e segurança, é preciso o bom uso da plataforma.

Objetivos da aula

- Conhecer os principais conceitos sobre a segurança de dados;
- Compreender qual é a Criticidade da segurança dos dados, na computação em nuvem;
- Conhecer e compreender os processos de criptografia para dados em trânsito e em repouso;
- Conhecer as mídias de backup e gerenciamento de chaves.

Resumo

Segurança de dados

Embora as unidades de armazenamento tenham preços variados e podem até ser baratas, ainda sim é um recurso não muito abundante na maioria dos sistemas, e desta forma a nuvem entra com uma proposta que une segurança com bom preço, evitando que o usuário tenha que adquirir novos discos ou SSD´s.

Resgatando a definição de que a nuvem, e de acordo com Dias et al. (2012, *apud* PEREIRA 2016, p.19), consiste em um conjunto de informações fornecidas por um ou mais clientes pode caracterizar a nuvem como um alvo adequado para ataques de potenciais invasores. Essas ameaças têm impacto direto nos requisitos de segurança da informação (disponibilidade, confidencialidade, integridade) e, consequentemente, podem comprometer toda a nuvem.

A garantia do cumprimento dos princípios de segurança está diretamente ligada aos modelos de entrega contratados pelos clientes de sistemas em nuvem. Por exemplo, no modelo de nuvem privada, o acesso pode ser restrito por trás do firewall do cliente local, mantendo assim o controle do nível de serviço e adesão às regras de segurança do cliente final ao invés de sistemas contratuais.

Para Kandukuri et al. (2009, *apud* PEREIRA 2016, p.19), os serviços prestados na rede devem obedecer a princípios que garantam a disponibilidade, integridade e confidencialidade dos dados. Os riscos devem ser avaliados antes da utilização da nuvem e quem migra para este sistema deve seguir as orientações pertinentes ao utilizar o produto final.

Desta forma, identificar e avaliar os ativos com suporte em nuvem é fundamental antes de migrar efetivamente para um sistema. Ao realizar migrações, as organizações devem considerar os riscos da manipulação de dados ou funções para a nuvem e se preparar para o pior, como destruição ou má gestão de ativos. Gerenciar a segurança na nuvem não é diferente de gerenciar a segurança em seu ambiente de TI. No entanto, com a computação em nuvem, o controle é gradualmente perdido, pois as preocupações de segurança podem ser deixadas para o provedor. À medida que as organizações amadurecem, seus sistemas de segurança também amadurecem.

A computação em nuvem visa reduzir custos para as empresas, por isso elas procuram, de acordo com Taurion (2009, *apud* Pereira, 2016, p. 20), fornecer serviços flexíveis para atender clientes específicos. Isso torna a segurança mais comprometida à medida que a responsabilidade pelo risco do consumidor aumenta. Esses requisitos podem ser considerados ao escolher um modelo implementado em nuvem. Por exemplo, no nível superior da pilha, SaaS, o consumidor define a segurança, enquanto no IaaS, o consumidor implementa a segurança

Criticidade da segurança dos dados

Os riscos aplicáveis à tecnologia da informação claramente existem na nuvem, e padrões e estratégias podem ser projetados para evitar ou abordar esses problemas em algumas perspectivas. Começando pelos domínios de governança podemos categorizar seguinte forma:

Governance and Risk Management – Uma das áreas de foco mais importantes para a governança de TI na computação em nuvem. Os processos de tomada de decisão voltados para a adoção desse novo

paradigma devem considerar os riscos inerentes à computação em nuvem.

Ele também aborda, para Pereira (2016) a capacidade de uma organização de gerenciar e medir os riscos comerciais impostos pela computação em nuvem. Itens como a precedência legal em caso de violação de acordo, a capacidade de organizações usuárias para avaliar adequadamente o risco de um provedor de nuvem, a responsabilidade para proteger dados sensíveis quando o usuário e o provedor podem falhar e, como as fronteiras internacionais podem afetar estas questões, são alguns dos itens discutidos;

Aspectos Legais e Electronic Discovery são um segundo domínio, e compreendem os problemas legais em potencial quando se utiliza computação em nuvem, como os requisitos de proteção da informação e de sistemas informáticos, leis de divulgação de violações de segurança, os requisitos regulatórios, requisitos de privacidade, as leis internacionais, entre outros. (PEREIRA 2016).

Sobre a Gestão do Ciclo de Vida da Informação, temos um domínio que inclui o gerenciamento de dados que são colocados na nuvem, itens em torno da identificação e controle de dados, bem como controles compensatórios que podem ser usados para lidar com a perda de controle físico ao mover um dado. A respeito da portabilidade e interoperabilidade, vamos ter um domínio que compreende a habilidade de mover dados/serviços de um provedor para outro, sem problemas de identificação e/ou acesso aos mesmos.

No sentido da segurança tradicional, da continuidade de negócios e recuperação de desastres, de acordo com Pereira (2016), temos um domínio capaz de determinar como a computação em nuvem afeta os processos e procedimentos operacionais atualmente usados para

programar a segurança, continuidade de negócios e recuperação de desastres. O foco desta área é discutir e analisar os possíveis riscos computação em nuvem na esperança de aumentar o diálogo e o debate sobre a grande demanda por melhores modelos de gerenciamento de riscos corporativos.

Em Data Center Operations, uma área que tem por objetivo avaliar a arquitetura e as operações dos provedores de data centers, vamos encontrar um domínio onde temos a resposta, a notificação e a correção de incidentes. Para Pereira (2016), a detecção, resposta, notificação e correção devem sempre ser precisas e oportunas de incidentes. Nesse sentido, os domínios precisam identificar elementos e/ou recursos que devem existir tanto no nível do provedor quanto no nível do usuário para permitir o processamento adequado de incidentes e perícias computacionais.

O Application Security é um domínio desenvolvido para proteger software ou aplicativos executados ou desenvolvidos na nuvem, o que inclui fatores como a necessidade de migrar ou projetar aplicativos para execução na nuvem. Já a Criptografia e o Gerenciamento de Chaves, constituem um domínio usado para identificar o uso de criptografia e gerenciamento de chaves de acesso. Nesta área, você pode analisar os problemas que ocorrem durante o uso, proteger o acesso aos recursos e proteger os dados.

No caso da virtualização, podemos compreender que não é possível hospedar todos os serviços/aplicativos em servidores dedicados, devido aos custos de manutenção e infraestrutura subutilizada. O modelo baseado em virtualização foi adotado pela necessidade de atender e, portanto, esta área se concentra em questões de segurança relacionadas à virtualização de sistema/hardware.

Criptografia e os dados em trânsito e em repouso

O objetivo da criptografia é impedir que espiões não autorizados decifrem a mensagem e impedir que a integridade da mensagem seja comprometida. Os generais usaram esse recurso para enviar mensagens às suas tropas para orientar seus movimentos durante a batalha. Se o mensageiro fosse interceptado no caminho, a mensagem não poderia ser detectada. A codificação da mensagem foi feita para confundir o inimigo.

A Comissão Brasileira de Controle da Internet (CGI.br), conforme apresenta Lima (2018), elaborou uma Cartilha de Segurança na Internet publicada pelo Centro Brasileiro de Pesquisas (Cert.br). Um formulário ou código criptografado que é um dos mecanismos de segurança mais importantes disponíveis para proteção contra riscos associados ao uso da Internet.

Esse tema pode parecer complicado a princípio, mas não é. Um estudo detalhado do tópico não é necessário para usar criptografia. Hoje, seu uso já está embutido em diversos dispositivos e aplicativos. O exemplo mais famoso é o WhatsApp, que recentemente passou a criptografar as mensagens para não expor os dados do usuário, garantindo a segurança de todas as conversas de ponta a ponta. A seguir podemos compreender melhor as possibilidades da criptografia:

- Proteger dados sigilosos armazenados em um computador – por exemplo, seu arquivo de senhas pessoais.

- Proteger uma partição do disco de trabalho separada do disco de sistemas, de forma que todas as informações ali gravadas ficam criptografadas.

- Proteger backups de qualquer tentativa de acesso indevido aos dados armazenados, em especial aqueles enviados p. fora da empresa em procedimento de armazenamento externo.

- Proteger a comunicação pela internet, como no caso do WhatsApp, mas também e-mails enviados/recebidos, transações bancárias. (LIMA 2018, p.113).

De forma geral, temos que a criptografia é utilizada para garantir a confidencialidade e integridade dos dados em trânsito, pois para proteger os dados do cliente em ambientes de nuvem, os fornecedores oferecem opções de segurança alternativas à criptografia para reduzir o risco de perda de dados. De acordo com Lima (2018), é importante que os provedores invistam na implementação de controles adequados em sua infraestrutura, entendendo fundamentalmente o verdadeiro significado de confidencialidade, integridade e disponibilidade das informações.

Podemos assim concluir que a segurança da informação assenta nestes três conceitos e a sua aplicação é essencial para a confiança nos dados acedidos na cloud. Esses três conceitos formam o que se chama de tríade informacional, conforme mostra a figura a seguir:

Figura 1: Tríade da segurança da informação.



Fonte: Lima (2018, p.114).

Conforme Lima (2018) defende, se as informações não forem criptografadas em trânsito, as informações estarão em trânsito como se estivessem armazenadas em um banco de dados, como é o caso hoje de sistemas críticos, como financeiro, bancário e dados vitais diários corporativos.

A tecnologia usa a criptografia para garantir a confidencialidade e integridade das informações em repouso. A criptografia de dados em repouso visa proteger as informações armazenadas em tecnologias de computação em nuvem, especialmente computadores e dispositivos móveis, em caso de perda ou roubo. (LIMA 2018).

Para esses tipos de dispositivos, geralmente recomendamos criptografar totalmente seus dados usando uma técnica chamada Full Disk Encryption (FDE). Desta forma, o procedimento se aplica a todos os dados armazenados, não sendo necessário avaliar quais tipos de dados são criptografados.

A maioria dos sistemas operacionais atuais vem com esse tipo de criptografia e os usuários só precisam habilitá-la. Depois que o usuá insere o código de segurança, esta é automaticamente a opção de criptografia de dados para o sistema operacional iOS do iPhone. Portanto, apenas o proprietário do iPhone pode inserir a senha para descompactá-lo. Caso contrário, eles nunca serão descriptografados novamente.

Mídias de backup e gerenciamento de chaves

Há décadas era costume proteger algo guardando em um cofre, com paredes grossas, estrutura externa metálica e super resistente e um sistema de abertura com combinação secreta. Mas no universo digital, embora soe estranho, também temos os cofres, apenas mudaram de formato. Uma importante forma de se guardar com segurança dados e arquivos, é com sistemas que realizam o seu backup, uma cópia de segurança.

Provedores de computação em nuvem oferecem soluções inteligentes e automatizadas para backups e acrescentam os benefícios da criptografia, podendo complementar a oferta com os seguintes elementos:

- O algoritmo de criptografia, que é o código de utilização para gerar um ou outro tipo de criptografia, que pode torná-la mais simples ou mais complexa de ser decifrada.

- O criptografador, que é o método utilizado para gerar a chave criptográfica, podendo esta ser um certificado. Este pode ser autoassinado ou emitido por CAs em organização (por exemplo, um computador Windows Server 2008 que execute

serviços de certificados do Active Directory ou CA pública como CertiSign).

- Uma chave assimétrica, que dispõe de um par de chaves: uma pública, que é disponibilizada gratuitamente a qualquer pessoa que queira enviar uma mensagem, e uma privada, que é mantida em segredo, para que somente o cliente saiba. (LIMA 2018, p.121).

Desta forma, Lima (2018), afirma que os dados são criptografados quando o backup é criado. Ao criptografar backups, é importante fazer uma cópia do certificado ou chave de criptografia. Se possível, a cópia deve ser feita em um local diferente daquele onde os dados criptografados foram copiados. Sem o certificado ou a chave de criptografia, os arquivos criptografados no backup não podem ser restaurados e ficam inutilizáveis.

A restauração desse tipo de backup é uma operação comum, e que em alguns casos é realizada diariamente, e quando o usuário possui o certificado instalado, é suficiente para garantir que os dados do backup sejam confiáveis e completos. Assim, podemos compreender que os benefícios de criptografar dados durante o backup são:

- Realiza-se a proteção dos dados no momento da criação do backup.
- Existe suporte para a criptografia dos backups feitos fora do backup gerenciado.
- Essa forma de criptografia pode dar opções até AES 256 bits, o que representa alta proteção para os dados.

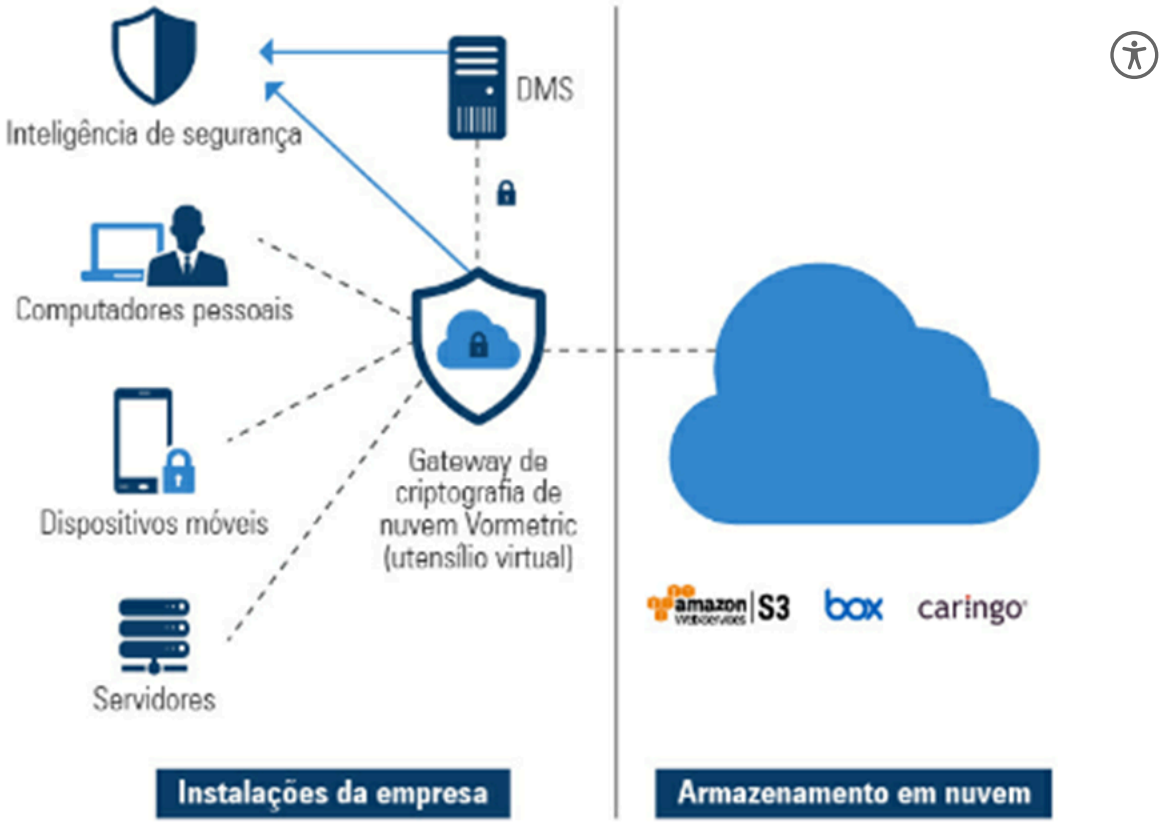
- É possível também integrar chaves de criptografia com provedores EKM (*Extended Key Management*). (LIMA 20 p.122).

Sobre o gerenciamento de chaves, Lima (2018), afirma que para muitas organizações, o gerenciamento de chaves de criptografia não está diretamente relacionado aos seus objetivos de negócios, por isso contratam empresas especializadas para lidar com esse problema, a fim de manter a integridade e a confiabilidade de suas informações. Esses serviços são contratados conforme a necessidade.

A escolha dessa opção é crescente e os provedores de serviços em nuvem já estão desenvolvendo soluções que atrairão clientes no mercado. A solução oferece um alto nível de serviço com proteção completa de dados e capacidade de processar informações compartilhadas e taxas criptografadas de alta velocidade. (LIMA 2018).

Pensando nisso, as empresas devem ter cuidado ao planejar os contratos com seus fornecedores, mas por outro lado, os fornecedores que desejam seguir esse novo modelo precisarão desenvolver altos padrões de gerenciamento de suas chaves criptográficas para atender às necessidades do cliente. A menos que um nível suficiente de confiança tenha sido estabelecido, a maioria das organizações conscientes do risco evita mover dados confidenciais para a nuvem por medo de expô-los a uma violação de confidencialidade e integridade. (LIMA 2018).

Figura 2: Modelo de gerenciamento de política e chaves de criptografia



Fonte: Vormetric (s.d apud LIMA 2018, p.125).

Este aplicativo de armazenamento em nuvem, de acordo com Lima (2018), depende do Data Security Manager para gerenciamento de políticas e chaves de criptografia. Com esta solução, os clientes não precisam mais depender de provedores de serviços em nuvem para gerenciar suas chaves criptografadas. Nenhum dado deixa as instalações da empresa sem criptografia ou sem proteção.

Como aplicar na prática o que aprendeu

Quer ter destaque na proteção de dados? Saiba como sanitizar dispositivos de armazenamento!

Quando a empresa necessita descartar algum dispositivo de armazenamento de dados, como um HD, um SSD ou qualquer tipo de

mídia removível, como um pen drive, o processo lógico é deletar e até mesmo formatar a unidade para evitar que arquivos importantes sejam recuperados por estranhos.

Mas deletar e formatar uma unidade não garantem a proteção dos dados da empresa, e é exatamente aí que entra a sanitização de dados, um processo que evita a possibilidade de recuperação de dados. Leia mais sobre este processo pesquisando o termo “Sanitização de dados”.

Conteúdo bônus

Tópicos avançados

LGPD e a Segurança dos Dados!

A Lei Geral de Proteção de Dados brasileira entra em vigor para que os dados pessoais sejam protegidos, e isso implica em criar formas de se oferecer a segurança adequada, pois de nada adianta a empresa ter processos corretos com dados pessoais e os manter de forma vulnerável.

Saiba mais sobre a LGPD na TI buscando por artigos a respeito e compreenda as necessidades do setor e como você pode se destacar!

Observação: Este conteúdo não será cobrado nas avaliações e estará, obrigatoriamente, presente nas videoaulas. Fique tranquilo(a)!

Referência Bibliográfica

LIMA, Adriano Carlos de**. Segurança na computação em nuvem**. - Editora Senac São Paulo, 2018.

PEREIRA, Adan Lucio... {et al.]. **Computação em nuvem:** a segurança da informação em ambientes na nuvem e em redes físicas. Brazilian Journal of Production Engineering, São Mateus, Vol. 2, N. º 1 (Julho). (2016). Editora CEUNES/DETEC. Disponível em: <https://periodicos.ufes.br/bjpe/article/download/EO02_2016/pdf/34008> Acesso em: 28 de dez, 2022.

Ir para questão